

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (Maven dependency:tree + versions + license, CVSS confirmed via NVD REST API) ·
Generated 2026-07-05 · Source SHA: `61ed8c3140d76e3a19a88954e834d39c9f7635fb`

Summary

Metric	Count
Total dependencies scanned	23 (8 direct, 15 transitive)
Total CVEs found	13
CRITICAL dependencies (by worst CVE)	3
HIGH dependencies	0
MEDIUM dependencies	3
LOW dependencies	0
Outdated dependencies	8 (all 8 direct deps have newer releases)
License violations	1 confirmed (+ 1 unresolvable/typosquat coordinate)
Supply-chain alerts	2

Scan note: OWASP Dependency-Check was launched (`org.owasp:dependency-check-maven:check`) but this environment has no `NVD_API_KEY` and no warm NVD DB volume; a cold sync of the 345,727-record NVD feed progressed at ~12% after 4.5 minutes and was aborted as infeasible for this session. Every CVSS score below was instead confirmed directly against the live NVD REST API (`cvssv3.1`), tagged `cvss_source: nvd` . `dependency:tree` , `versions:display-dependency-updates` and the license aggregate report all ran to completion normally.

Known-vulnerable dependencies

Dependency	Version	Top CVE	CVSS	Severity	Fix version
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.17.1
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2021-44228	10.0	CRITICAL	2.17.1
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379	9.8	CRITICAL	2.13.4.2
com.google.guava:guava	24.1.1-jre	CVE-2018-10237	5.9	MEDIUM	32.0.0-jre
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	3.18.0
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2.7
mysql:mysql-connector-java	8.0.30	— (GPL-2.0-with-FOSS-exception license)	—	policy violation	8.0.33 (license unresolved)

All CVEs found

CVE	Dependency	CVSS	Severity
CVE-2021-44228	log4j-core / log4j-api	10.0	CRITICAL
CVE-2021-45046	log4j-core / log4j-api	9.0	CRITICAL
CVE-2021-44832	log4j-core / log4j-api	6.6	MEDIUM
CVE-2021-45105	log4j-core / log4j-api	5.9	MEDIUM
CVE-2019-14379	jackson-databind	9.8	CRITICAL
CVE-2019-14540	jackson-databind	9.8	CRITICAL
CVE-2020-36518	jackson-databind	7.5	HIGH
CVE-2022-42003	jackson-databind	7.5	HIGH
CVE-2018-10237	guava	5.9	MEDIUM
CVE-2023-2976	guava	5.5	MEDIUM
CVE-2020-8908	guava	3.3	LOW
CVE-2025-48924	commons-lang3	5.3	MEDIUM
CVE-2021-29425	commons-io	4.8	MEDIUM

License findings

Dependency	License	Status
mysql:mysql-connector-java:8.0.30	GNU GPL v2 with FOSS exception	VIOLATION — permissive-only policy
org.checkerframework:checker-compat-qual:2.0.0 (transitive, via guava)	GPL-2.0-with-classpath-exception / MIT (dual)	WARN — ambiguous dual license, review
All other 21 dependencies	Apache-2.0 / BSD-3-Clause / MIT / EPL-2.0	OK

Supply-chain alerts

CRITICAL — Typosquatted dependency. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonates the legitimate `com.fasterxml.jackson.core`; the coordinate does not exist on Maven Central and blocks dependency resolution outright. **Remove immediately.**

HIGH — Untrusted repository. `http://insecure-mirror.example.net/maven2` is a plain-HTTP Maven repository (MITM artifact-injection risk). It was blocked by Maven's built-in HTTP mirror blocker during this scan. Remove or replace with HTTPS/Central.